COLLEGE PROJECT / VERIFIED LOCAL DELIVERY

Gyanix learning portal

Audit, improvements and QA verification

15 October 2026 | Source branch: fix/qa-audit

34 original findings	115 passing tests	5 added requirements
31 code remediations + 3 payment retirements	0 failed / 0 skipped	UI, free access, speed, RAG and chat

Implementation complete locally; live AI evaluation pending

The requested dashboards, payment removal, performance work and role-secured floating assistant are implemented. Local workflow, API, build, dependency and container checks passed. A real LLM key has not been configured, so live multilingual and semantic retrieval quality is not marked verified.

No code was pushed or deployed. Private credentials, database backups, dependency folders and build outputs are excluded from the delivery archive.

Repository: github.com/Jainesh-8305/gyanix-learning-portal

Baseline: 177f8a9354f4cfb417075c3bc0f9f2811e5d0181

REQUESTED REQUIREMENTS

What changed

Dashboard UI/UX

Shared role navigation, calm navy styling, spacing and hierarchy, accessible tables and empty/error states. Student assignments, submissions, feedback, progress, notes, flashcards, quizzes, calendar and certificates remain reachable. Instructor courses, rosters, gradebook, studios, resource hubs and reviews remain reachable. Admin governance, accounts and enrollment records remain available.

Remove payments

Deleted gateway SDKs, backend payment routes/services, checkout, pricing forms, receipts and revenue views. Course/enrollment financial fields are rejected or redacted. All published courses enroll free, including legacy-priced courses. Publication, role and membership restrictions still apply. Backed-up local migration preserves learning history.

Performance and smoothness

Removed site-wide animated canvas/cursor loops and unused frontend packages. Heavy studios and assistant load on demand with local loading states. Role views fetch only needed data; student dashboard uses one bounded aggregate endpoint. Added query indexes, bounded lists, debounce and account-scoped cache reuse with refresh behavior.

Intelligent multilingual assistant

Configurable OpenAI Responses model gpt-5.4-mini, structured replies, recent server-owned conversation turns and contextual retrieval. Hybrid lexical/embedding ranking uses reviewed role-filtered documentation; current authorized summaries are fetched separately. Supports natural language instructions including Hindi, Gujarati and English. Actual multilingual model quality remains pending credentials.

Floating assistant UI

Signed-in pages have a small corner launcher. The lazy chat window offers language choice, safe source links, history, new conversation, cancellation, keyboard close/focus handling and private owned conversations. It is no longer a dashboard card.

Additional issues caught and fixed

E01: New dashboard crash for an unsubmitted assignment - empty projection normalized and regression added. E02: Generic success after study-tool API errors - removed; source errors stay visible. E03: Wrong Gujarati quiz match - retrieval expansion corrected. E04: Protected videos appeared missing - safe availability metadata added. E05: Lazy tools hid the workspace - local loaders and labelled question controls added.

Preserved workflows

Accounts and password recovery, curriculum editing and moderation, classroom codes, direct lesson learning, discussions, assessments, completion certificates, private notes, SM-2 flashcards, review history, instructor grading and resource sharing remain available. Payment functionality was intentionally removed. Lightweight presentation replaces the former global animation workload.

SECURITY BY BACKEND PREDICATES

Assistant architecture and privacy

1 / Authenticate the current account

Verify database role, activation and token version. Ignore client role/history/context overrides. Read/continue conversations only for their owner and current role.

2 / Filter before retrieval

A reviewed documentation corpus is filtered by role before BM25 or vector ranking. Only public workflow text is embedded or cached. Private data has no shared vector index.

3 / Fetch minimal authorized evidence

Students: own published enrollments, own notes and own grade/feedback only. Instructors: own course summaries. Admins: platform totals. Course-specific requests require permitted membership or ownership. Reference keys, other students, passwords and service secrets are excluded.

4 / Generate a bounded answer

OpenAI Responses uses store=false, structured output and recent owned turns. Model input treats evidence as untrusted text, permits no mutation tools, and asks for natural language matching. Citation IDs are intersected with retrieved documents; safe text rendering prevents HTML injection.

5 / Retain and degrade honestly

20 messages/minute per account; 100 retained conversations; 40 messages per conversation; 30-day expiry; generation lock; cancellation and provider timeouts. Provider failures show retrieved help instead of a fake live answer.

Verified boundary

Negative tests include unauthenticated calls, foreign courses/threads, role spoofing/change, inactive accounts, hidden keys, foreign canaries, own-grade isolation, provider-context assembly, outages, citation filtering and quotas. Prompt instructions supplement these checks; they are not the access-control boundary.

Live provider limitation

Live OpenAI generation and semantic embeddings were not exercised: a credential file was selected, but its exact local path has not been supplied. Controlled provider mocks validate input assembly, history, failure and citation behavior; these do not validate model quality.

EVIDENCE, NOT BLANKET GUARANTEES

QA and performance results

Check	Result
Backend regression	115 passed; 0 failed/skipped
Frontend + backend strict lint	Passed, zero warnings
TypeScript + Next production build	Passed
Dependency advisory snapshot	0 frontend / 0 backend
Docker	Both latest images build/start; non-root
Browser	Role flows, 390/1440px and floating chat

Measured initial JavaScript

Student: 798.2 -> 688.5 KiB (13.7% smaller). Current overview API: median 7.19 ms / max 21.34 ms over 12 local requests.

Instructor: 768.1 -> 686.4 KiB (10.6% smaller). Current overview API: median 1.99 ms / max 3.30 ms over 12 local requests.

Admin: 677.4 -> 674.7 KiB (0.4% smaller). Current overview API: median 2.15 ms / max 3.61 ms over 12 local requests.

Method and limits

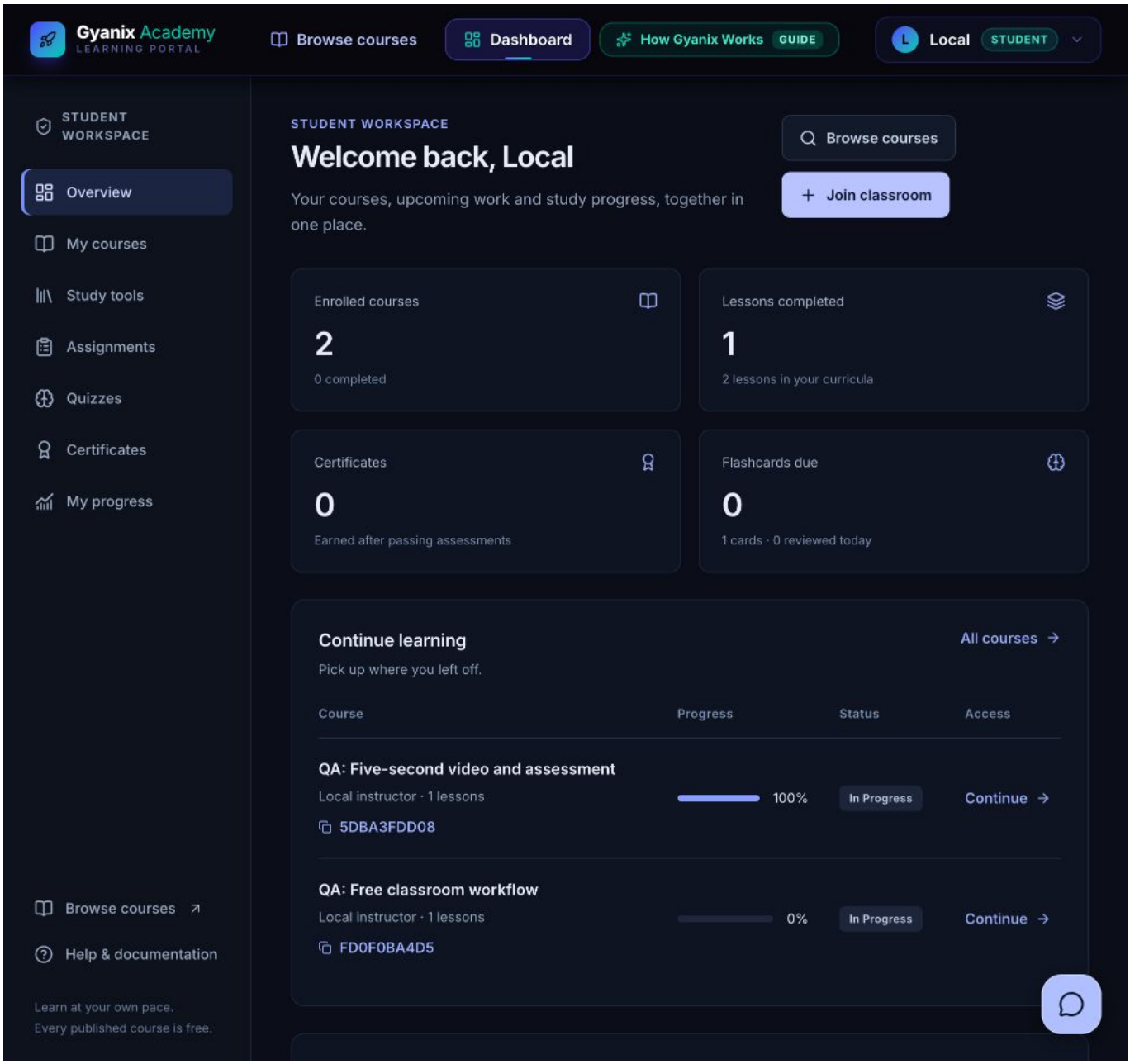
JavaScript totals count uncompressed script assets referenced by dashboard HTML. This is not a measure of authenticated LCP, INP or all later route chunks. The same local method was used before and after; fixture data changed. Small local API timings do not establish a latency improvement or production capacity.

Workflow proof

Created a course, saved private lesson media/duration, submitted it, approved it as admin and enrolled as a student with no checkout. Student submitted a real answer; instructor saved 85/100 and feedback; student reopened the matching result. A three-question saved quiz scored 3/3. Hindi and Gujarati help matched role-specific articles; chat persisted across navigation.

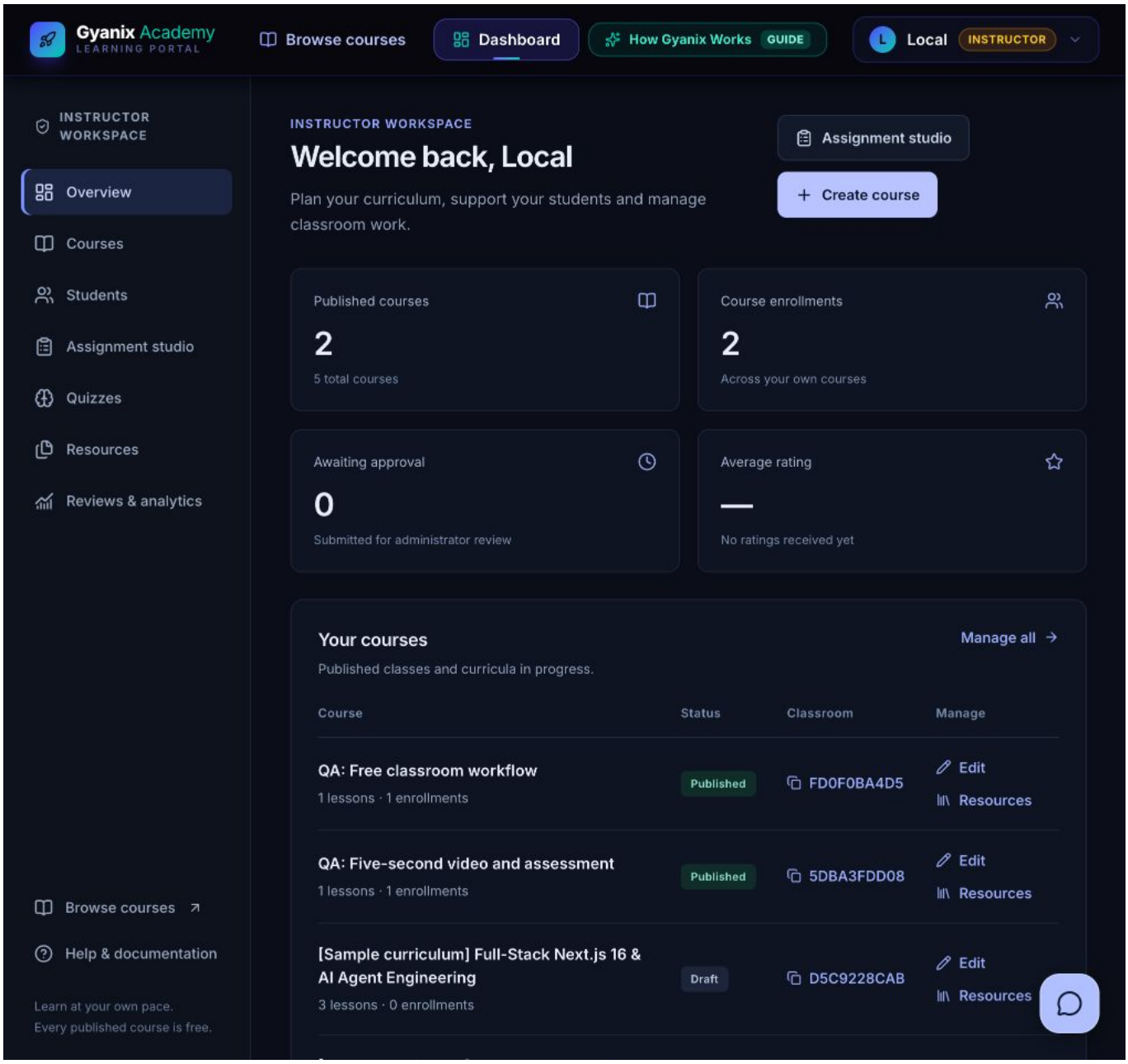
Dashboard evidence

Student overview



Overview keeps course progress, classroom access, assignments and study tools together. The corner assistant is available without taking a dashboard card slot.

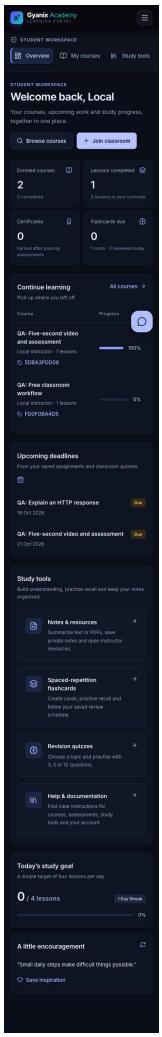
Instructor workspace



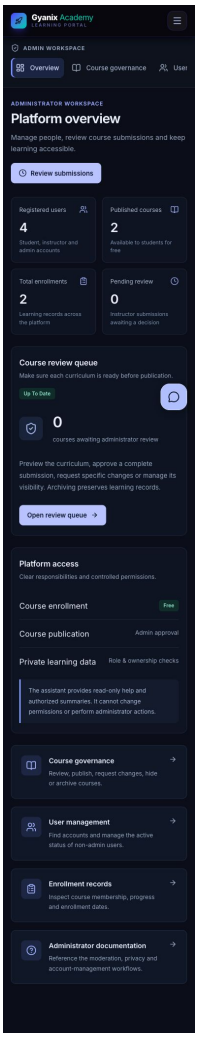
Teaching controls preserve curriculum editing, rosters, grading, quiz creation, resource sharing and review analytics.

390PX RESPONSIVE CHECKS

Mobile and feedback evidence

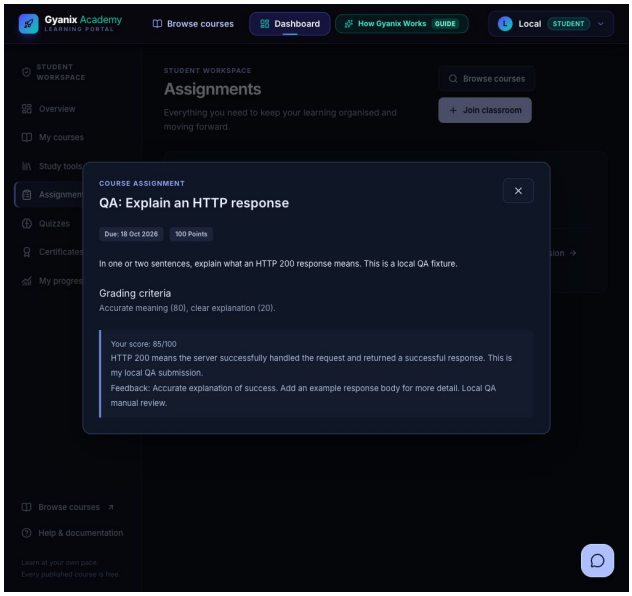






Student dashboard, floating Hindi help, and admin overview. All three dashboard roles had document scrollWidth equal to clientWidth at 390px and 1440px. Wide data tables scroll within their panel.

End-to-end instructor feedback



ORIGINAL AUDIT RETAINED; FINAL BEHAVIOR SUPERSEDES PAYMENT RECOMMENDATIONS

Finding-by-finding resolution

The original audit had 4 Critical, 12 High, 17 Medium and 1 Low finding groups. All 34 are represented below. Three payment-specific groups are retired by complete gateway removal. Other groups have local code remediation; remaining external-service validation is stated explicitly. Historical fix-phase UI references are evidence from the earlier run. Current backend regression was rerun for this delivery.

F01 | Critical | Password reset permits account takeover

Implemented locally

Recommended fix: Return one generic response for known/unknown emails. Deliver tokens only through email; remove direct links and token logs in every environment exposed to users. Rate-limit reset requests.

Delivered: Reset replies are identical for known/unknown addresses. Tokens only go to email, are single-use, expire, and reset requests are rate-limited. UI no longer exposes a reset link.

Verification: Reset response generic and token private; Email reset consumes token and revokes existing sessions

Source: backend/src/controllers/auth.controller.js

Limit / next validation: SMTP inbox delivery still needs configured credentials.

F02 | Critical | Public seeding restores known administrator credentials

Implemented locally

Recommended fix: Remove the HTTP seed route and automatic production seeding. Provide an explicit local-only seed command with generated test accounts; never update an existing account password during seeding.

Delivered: Removed public HTTP seeding and startup seeding. Explicit loopback-only seed command creates random local credentials and preserves existing users/passwords.

Verification: Seed endpoint removed; seed-local.js inspection

Source: backend/src/utils/seed-local.js

Limit / next validation: Existing installations must rotate/remove historical demo accounts before exposure.

F03 | Critical | Production test-purchase route bypasses payment

Retired by payment removal

Recommended fix: Remove this route from production. Use Stripe test mode and a verified payment-success event for test purchases, with explicitly separated demo accounting.

Delivered: Removed payment routes, handlers, gateway SDKs, checkout page, receipts, financial UI and pricing fields. Published courses enroll for free. Legacy financial fields are redacted and the backed-up local database was migrated without deleting learning records.

Verification: 115-test regression suite: legacy-priced courses enroll for free, financial payloads rejected, legacy fields redacted, removed gateway URLs return 404; UI-11 free classroom lifecycle.

Source: backend/src/controllers/enrollment.controller.js

Limit / next validation: No payment provider integration remains; historical order collections are retained offline in the database and are not exposed by the app.

F04 | Critical | Client-forged quiz earns a paid-course certificate

Implemented locally

Recommended fix: Store a server-created assessment attempt and answer key. Accept only attempt ID and student answers. Recheck enrollment, course status, valid lesson completion, time/attempt limits and role before grading or issuing a certificate.

Delivered: Certification uses server-stored keys, enrollment, published status, validated lessons and owned timed attempts. Client question/key payloads are rejected. Verification requires a passed stored attempt.

Verification: Forged paid certificate blocked; Supplied question key rejected; Server scores stored key and issues backed certificate

Source: backend/src/services/assessment.service.js

Limit / next validation: Offline question templates remain generic practice content, not an academic accreditation.

F05 | High | Course editor silently loses private video URLs

Implemented locally

Recommended fix: Return full edit content to the owning instructor and admin through an ownership-protected endpoint. Ensure read redaction cannot be saved back as destructive updates.

Delivered: Owners/admins retain private lesson media when editing. Public responses redact protected media. Editor persists the correct videoDuration field and stops review submission after a save failure.

Verification: Owner retains private URLs and totals; Prior fix-phase browser FIX-UI-09

Source: backend/src/controllers/course.controller.js

Limit / next validation: Cloudinary upload delivery requires real service credentials; direct lesson URLs were tested.

F06 | High | Invented lesson IDs complete a course

Implemented locally

Recommended fix: Validate lesson existence in that course, unique completion, finite nonnegative watch time, and the intended completion policy. Calculate progress from valid curriculum IDs only.

Delivered: Completion rejects nonexistent lessons and invented watch time. Bounded server heartbeats credit elapsed sessions; valid saved curriculum determines progress. Progress alone does not issue a certificate.

Verification: Invalid lesson rejected; Faked watch time rejected; Server watch heartbeat validates completion without issuing certificate; Prior fix-phase browser FIX-UI-01

Source: backend/src/controllers/enrollment.controller.js

Limit / next validation: Heartbeats are a practical progress gate, not tamper-proof evidence of human attention.

F07 | High | Instructor boundaries fail for quizzes and assignments

Implemented locally

Recommended fix: Resolve the course owner for every read/create operation; permit only that owner, admin, or enrolled students with redacted responses.

Delivered: Quiz/assignment reads and creation require course ownership or permitted enrollment. Students cannot read reference keys; other instructors cannot manage these records.

Verification: Other teacher quiz read/create blocked; Assignment other teacher read/create blocked; Student private answer key redacted

Source: backend/src/controllers/quiz.controller.js

F08 | High | Instructor updates bypass moderation

Implemented locally

Recommended fix: Whitelist editable course fields and implement explicit role-based status transitions. Reserve moderation fields and published state for admin or a documented approved-revision workflow.

Delivered: Whitelisted instructor updates reject moderation/system fields. Editing a published course returns it to draft. Only administrators publish; review validates lecture media.

Verification: Moderation mass assignment blocked; Self publishing blocked; Review submission; browser instructor review flow

Source: backend/src/controllers/course.controller.js

F09 | High | Advertised classroom and AI studio APIs are missing

Implemented locally

Recommended fix: Implement and test the intended backend contracts and persistence, or clearly disable/label these features as planned. Add a frontend/backend route contract check.

Delivered: Implemented batch join, persisted batch quizzes, assignment drafting, instructor gradebook and owner-controlled resource hubs. Validated batch deadlines and HTTP(S) resource links.

Verification: Instructor batch quiz dispatch; Instructor gradebook exists; Resource hub saves; Prior fix-phase browser FIX-UI-07/08

Source: backend/src/routes/course.routes.js

Limit / next validation: Drafts from offline templates need instructor review; optional live AI calls were not verified.

F10 | High | Discussion authorization can be bypassed

Implemented locally

Recommended fix: Authorize against discussion.course, enforce path course equality, and restrict resolve to author, course instructor or admin.

Delivered: Discussion course association and enrollment are checked on replies/votes. Resolution is limited to author, course owner or admin.

Verification: Discussion membership and course association

Source: backend/src/controllers/discussion.controller.js

F11 | High | AI memory feedback and notes are public

Implemented locally

Recommended fix: Require authentication and per-user scoping for memory. Return aggregate metrics without notes/names to public callers. Add per-user quotas and strict input sizes for AI calls.

Delivered: AI routes require authentication and per-account quotas. Feedback and insights are scoped to the signed-in account and derived from actual saved records.

Verification: AI authentication cases; Private feedback, real counts

Source: backend/src/routes/ai.routes.js

F12 | High | Saved notes leak between accounts on one browser

Implemented locally

Recommended fix: Store notes in an authenticated per-user backend library; at minimum use user-scoped local keys and clear in-memory state on logout.

Delivered: Saved notes use account-owned API storage. Removed shared browser-note storage and starter-note claims; account changes clear the SWR cache boundary.

Verification: Private notes persisted and isolated; SWRProvider inspection

Source: frontend/src/components/providers/SWRProvider.tsx

Limit / next validation: Old shared localStorage notes are deliberately not imported into an arbitrary account.

F13 | High | Valid Stripe webhook is rejected before enrollment

Retired by payment removal

Recommended fix: Register the raw-body webhook before global JSON parsing, then validate signature and implement durable idempotency/error handling. Stripe's official documentation requires unmodified raw bytes.

Delivered: Removed payment routes, handlers, gateway SDKs, checkout page, receipts, financial UI and pricing fields. Published courses enroll for free. Legacy financial fields are redacted and the backed-up local database was migrated without deleting learning records.

Verification: 115-test regression suite: legacy-priced courses enroll for free, financial payloads rejected, legacy fields redacted, removed gateway URLs return 404; UI-11 free classroom lifecycle.

Source: backend/src/controllers/enrollment.controller.js

Limit / next validation: No payment provider integration remains; historical order collections are retained offline in the database and are not exposed by the app.

F14 | High | Default mobile lesson layout clips the video

Implemented locally

Recommended fix: Use a closed-by-default drawer/overlay on narrow screens and preserve a full-width video; label the toggle and check viewport changes.

Delivered: Lesson navigation starts closed and overlays rather than shrinks the player. Mobile overlay has a visible close button below the navbar; hidden content is inert.

Verification: Prior fix-phase browser FIX-UI-04; 390px viewport, scrollWidth=clientWidth=390

Source: frontend/src/app/courses/[id]/learn/page.tsx

F15 | High | Deleting courses leaves broken database references

Implemented locally

Recommended fix: Prefer archive/soft-delete for courses with learning records. Define dependent-record retention/cascade policy and make frontend handling of removed courses explicit.

Delivered: Course deletion archives the course instead of breaking enrollment/quiz/assignment references; enrollment list also tolerates missing historical records.

Verification: Archive retains referenced records

Source: backend/src/controllers/course.controller.js

Limit / next validation: Historical corruption should be reconciled using a backup before any deployment.

F16 | High | Dependency audits report vulnerable production packages

Implemented locally

Recommended fix: Review each recorded advisory and reachable feature; upgrade to patched compatible releases and retest. Do not blindly use npm audit fix --force: suggested resolutions include major downgrades for some development packages.

Delivered: Updated application and development dependencies and lockfiles. Replaced the vulnerable Next lint dependency tree with direct ESLint, TypeScript, Hooks, accessibility and unused-import rules.

Verification: backend-audit.json and frontend-audit.json: total=0

Source: frontend/eslint.config.mjs

Limit / next validation: Audit results are a dated advisory snapshot, not a guarantee that future advisories will remain zero.

F17 | Medium | Password reset leaves old sessions valid

Implemented locally

Recommended fix: Add session/token version or passwordChangedAt validation and revoke sessions on reset; define logout/session expiry behavior.

Delivered: JWT tokenVersion is checked against the current account. Password reset increments it and rejects all previously issued sessions.

Verification: Email reset consumes token and revokes existing sessions

Source: backend/src/middleware/auth.js

F18 | Medium | Role navigation and hydration guards are inconsistent

Implemented locally

Recommended fix: Centralize hydrated authentication and role guards, add an admin dashboard mapping, and honor a validated same-origin return path after login.

Delivered: Central session boundary waits for persisted-auth hydration and server session validation before private content renders. Role dashboards, safe return paths and user-scoped caches are consistent.

Verification: Prior fix-phase browser FIX-UI-06; administrator login/direct-load/reload checks

Source: frontend/src/components/providers/AuthBoundary.tsx

F19 | Medium | Draft/unpublished course access is not enforced

Implemented locally

Recommended fix: Restrict unpublished details to the course owner/admin and permit enrollments only for published, available courses.

Delivered: Unpublished course details are owner/admin only. Enrollment, student material and assessments require published status and permitted membership. Every published course is free; legacy price fields do not restrict enrollment.

Verification: Draft read/enrollment denial tests; legacy free enrollment and classroom-code tests; UI-11.

Source: backend/src/controllers/course.controller.js

F20 | Medium | Quiz attempts and time limits lack server enforcement

Implemented locally

Recommended fix: Persist per-student attempts with start/end timestamps, immutable scoring, maximum-attempt checks and review release policy.

Delivered: Persisted immutable attempts enforce ownership, expiry, attempt count and replay protection. Keys are hidden until submission. Both quiz timers use the server deadline.

Verification: Standard attempt scores, persists and enforces maxAttempts; Expired attempt refused; Submitted attempt cannot replay

Source: backend/src/services/assessment.service.js

F21 | Medium | Assignment deadlines and grade range are not validated

Implemented locally

Recommended fix: Validate finite score in [0,maxScore], deadline policy, required answer content and any late-submission exceptions.

Delivered: Assignment submissions validate role, deadline, required answer and duplicates. Grades must be finite numbers within the assignment range; unavailable AI grading stays pending.

Verification: Assignment deadline enforced; Invalid grade cases; Valid grade saved; Unconfigured live grader fails clearly

Source: backend/src/controllers/assignment.controller.js

Limit / next validation: Live OpenAI grading quality still requires service credentials and human review.

F22 | Medium | Flashcards are a temporary demo, not persisted SM-2

Implemented locally

Recommended fix: Label the current deck as a demo or implement per-user cards, repetition/ease/interval/due fields, durable ratings and documented keyboard controls.

Delivered: Implemented per-account cards, SM-2 repetition/ease/interval/due fields and persistent reviews. Space reveals cards; 1-4 rate them, including when controls have keyboard focus.

Verification: SM-2 reviews persist per student; SM-2 schedule math; Prior fix-phase browser FIX-UI-02/03/05

Source: frontend/src/app/dashboard/student/flashcards/page.tsx

F23 | Medium | Displayed history, counts and ratings are fabricated

Implemented locally

Recommended fix: Derive metrics from real user records and show honest empty states. Mark illustrative demo values clearly and recompute course lesson/duration totals when saving.

Delivered: History, activity, feedback counts, streaks, lesson totals and SRS metrics derive from stored records. Empty ratings show zero/no ratings. Homepage sample grades are labelled illustrative.

Verification: Fresh account history and flashcards are zero; Owner retains private URLs and totals; final instructor screenshot

Source: frontend/src/app/dashboard/student/page.tsx

Limit / next validation: Sample curricula are draft examples; a short synthetic video exists only in the ignored local browser fixture.

F24 | Medium | AI provider and self-learning claims exceed the implementation

Implemented locally

Recommended fix: Show actual provider/model and fallback status. Describe stored feedback accurately. Only advertise transcript ingestion, RAG or training after implementing and verifying it.

Delivered: Assistant now uses configurable OpenAI Responses, owned server history and role-filtered hybrid RAG. A floating window shows sources and truthful provider mode. Unsupported source errors no longer produce generic success output. Offline templates remain labelled; they do not self-train a model.

Verification: Backend chat/provider-input/privacy regression; Hindi/Gujarati retrieval UI; history persistence; live-provider quality pending.

Source: backend/src/services/chat.service.js

Limit / next validation: Actual OpenAI generation, embeddings and multilingual follow-up quality require the exact local credential file path. No real provider success is claimed.

F25 | Medium | Three-question selection generates five questions

Implemented locally

Recommended fix: Agree one count contract across UI and backend; validate allowed counts and enforce the exact requested length for generated and fallback quizzes.

Delivered: API accepts only 3, 5 or 10 and enforces the exact requested length in offline and provider processing. Generated question enum fields match the quiz persistence contract.

Verification: Exact offline quiz count 3/5/10

Source: backend/src/routes/ai.routes.js

Limit / next validation: Provider failure/fallback handling is covered locally; real provider output remains unverified.

F26 | Medium | Catalog inputs return server errors or unbounded results

Implemented locally

Recommended fix: Validate IDs, positive integer page, capped limit, category/level and sort allowlists. Return stable 400/404 errors without database details.

Delivered: Route IDs, page/limit bounds and supported sorts are validated. Removed price filters are rejected; production errors return safe messages without database stack traces.

Verification: Invalid catalog inputs and ID tests; removed min/max pricing filters rejected.

Source: backend/src/utils/http.js

F27 | Medium | Unreadable PDFs produce successful generic notes

Implemented locally

Recommended fix: Require extracted text or explicitly disclose unreadable/scanned documents and OCR needs; validate file types/count/aggregate size and separate video-link-only behavior.

Delivered: Notes accept text PDFs or pasted transcripts, reject corrupt/no-text PDFs and video URLs without transcripts, and limit file count, per-file size and total uploaded bytes. The notes screen retains an inline source error instead of showing fabricated generated content.

Verification: Corrupt PDF rejected; Video source requires transcript; Notes generation labelled offline; UI-14 persistent transcript-required error with no generated notes.

Source: backend/src/routes/ai.routes.js

Limit / next validation: Scanned documents require OCR outside this implementation.

F28 | Medium | Discount price and payment amount disagree

Retired by payment removal

Recommended fix: Define one server-side effective-price/currency calculation and use it for catalog, checkout, payment validation, accounting and receipts.

Delivered: Removed payment routes, handlers, gateway SDKs, checkout page, receipts, financial UI and pricing fields. Published courses enroll for free. Legacy financial fields are redacted and the backed-up local database was migrated without deleting learning records.

Verification: 115-test regression suite: legacy-priced courses enroll for free, financial payloads rejected, legacy fields redacted, removed gateway URLs return 404; UI-11 free classroom lifecycle.

Source: backend/src/controllers/enrollment.controller.js

Limit / next validation: No payment provider integration remains; historical order collections are retained offline in the database and are not exposed by the app.

F29 | Medium | Accessibility semantics are incomplete

Implemented locally

Recommended fix: Connect label/htmlFor/id, add error associations, name icon controls, use real buttons for cards, and provide modal focus entry/trap/restore with Escape dismissal.

Delivered: Login has associated labels/error references. Named modal dialogs support focus entry/trapping/restoration and Escape. Cards are buttons; icon and sidebar controls have accessible names. Added shared workspace navigation, active states, skip link, associated legacy form labels, named quiz controls, floating assistant language controls and reduced-motion styling.

Verification: Accessible browser login; assignment modal Escape restores focus; flashcard Space/numeric controls; mobile close control; 390/1440px dashboard overflow checks; final quiz form labels and shell-preserving lazy loading.

Source: frontend/src/hooks/useDialogFocus.ts

Limit / next validation: Keyboard/browser checks are targeted; no formal assistive-technology certification is claimed.

F30 | Medium | Quality checks and regression suite are not ready

Implemented locally

Recommended fix: Resolve meaningful lint failures, install/configure a real test runner, remove pass-with-no-tests as the only test expectation, and add regression cases for confirmed defects plus CI.

Delivered: Real Node integration suite replaces the missing Jest command. Added CI for Mongo-backed tests, both lint checks, types, build and audits; meaningful lint failures are corrected.

Verification: 115 backend tests pass; strict frontend/backend lint, TypeScript and production build pass. CI definition added; no hosted GitHub run claimed.

Source: backend/test/portal.test.js

Limit / next validation: CI workflow is added locally; no GitHub run is claimed because changes were not pushed.

F31 | Medium | Docker recipe expects a missing production artifact

Implemented locally

Recommended fix: Choose a consistent development or production compose workflow; enable standalone for that runner, supply public variables at build time and remove incompatible production source mounts.

Delivered: Enabled standalone Next output. Docker uses non-root runners, build-time public API variables and no source mounts hiding artifacts. Both images build and run against local Mongo.

Verification: docker-build.txt; docker-runtime.json; browser Docker catalog verification

Source: docker-compose.yml

Limit / next validation: Docker smoke uses isolated loopback ports and a separate empty QA database; no public deployment occurred.

F32 | Medium | CORS allows every origin with credentials

Implemented locally

Recommended fix: Use an exact configured origin allowlist and reject unknown origins. Keep authenticated endpoint permissions as the primary security control.

Delivered: CORS allows only exact configured frontend origins and denies untrusted origins. Permission checks remain mandatory on authenticated endpoints.

Verification: Unknown origin has no CORS access

Source: backend/server.js

F33 | Medium | Public certificate lookup exposes email addresses

Implemented locally

Recommended fix: Return only fields needed for verification, and define recipient consent and revocation behavior.

Delivered: Public certificate verification returns only recipient display fields and credential data. Email is excluded; invalid/unbacked credentials are rejected. Direct PDF downloads work.

Verification: Public certificate email private and PDF works

Source: backend/src/routes/user.routes.js

F34 | Low | Quick-start and public claims are inconsistent

Implemented locally

Recommended fix: Update setup to tested versions/env names, label sample curricula clearly, align free/paid wording and feature status, and read URL filters into state.

Delivered: Rewrote README, architecture and internship documentation for the payment-free app, optional server-side AI, role-filtered RAG and secure local setup. Public content, offline labels and notes export copy describe actual behavior.

Verification: Source/documentation review; local production build, Docker startup, classroom lifecycle and dashboard browser checks.

Source: README.md

Limit / next validation: Real SMTP delivery, Cloudinary uploads, OpenAI quality, second-machine setup and public hosting are not validated in this local run.

RELIABLE LOCAL IMPLEMENTATION; EXTERNAL SERVICES STILL REQUIRE PROOF

Handover and outstanding validation

1. Live OpenAI generation and semantic embeddings were not exercised: a credential file was selected, but its exact local path has not been supplied. Controlled provider mocks validate input assembly, history, failure and citation behavior; these do not validate model quality.

2. SMTP inbox delivery and Cloudinary upload delivery still require real configured service credentials. Reset token lifecycle is covered using a local captured-email fixture. No external emails were sent by this QA run.

3. No public deployment, push, hosted CI run, second-machine installation, cross-browser matrix, production-scale load test or formal WCAG certification is claimed.

4. Offline study/quiz templates are generic examples that require instructor review. Seed curricula are labelled samples. The five-second QA video is a synthetic fixture, not course content. Project completion certificates are not academic accreditation.

5. Watch-time heartbeats reduce trivial progress forgery but do not prove human attention. LLM output still needs factual review; permissions are enforced by database predicates rather than trusting model obedience.

6. Before exposing any existing installation, rotate historical demo accounts and previously exposed secrets, use HTTPS and a private/authenticated database, back up and validate the free-access migration. These deployment-specific checks cannot be completed against an unknown live installation.

Run and reproduce

Follow README.md for Node 22.22+, MongoDB, separate npm installs and server-only env configuration. Run backend tests, both strict lint commands, frontend typecheck/build and both npm audits. Use fresh random local seed accounts; do not reuse historical demo passwords.

Current local endpoints

Frontend: http://localhost:3100 | API: http://localhost:5100
Private QA MongoDB: 127.0.0.1:27028
Delivery excludes .audit-runtime, .env credentials, dependencies, compiled assets and synthetic QA video. Source, locks, setup docs, regression tests, report, matrix and redacted evidence are included.

Provider implementation references

https://developers.openai.com/api/docs/guides/embeddings

https://developers.openai.com/api/docs/guides/text

https://developers.openai.com/api/docs/guides/safety-best-practices

https://developers.openai.com/api/docs/models/gpt-5.4-mini